

1. Malware Concepts

What is Malware? Malicious software designed to damage or disable computer systems, or give limited/full control to the attacker for theft or fraud. It includes: viruses, worms, Trojans, rootkits, backdoors, botnets, ransomware, spyware, adware, crypters, keyloggers, etc.

Malicious Activities of Malware:

- Attack browsers and track websites.
- Slow down systems.
- Cause hardware failure.
- Steal personal information (contacts, financial data, credentials).
- Erase valuable information.
- Attack additional systems.
- Send spam.
- Spy on user activities and capture screenshots.
- Make infected system part of a botnet.

Ways for Malware to Enter a System

- **Instant Messenger Applications:** Via shared files (e.g., Facebook Messenger, WhatsApp).
- **Portable Hardware Media/Removable Devices:** USB drives, memory cards (e.g., via Autorun feature).
- **Browser and Email Software Bugs:** Exploiting vulnerabilities in outdated browsers or email clients.
- **Insecure Patch Management:** Unpatched software is a high risk (e.g., Parse Server, Pandora FMS, WPVibes, Microsoft Edge vulnerabilities).
- **Rogue/Decoy Applications:** Free, seemingly legitimate programs that contain malware.
- **Untrusted Sites & Free Web Applications/Software:** Websites offering pirated or "underground" software, or professional-looking malicious sites.
- **Downloading Files from the Internet:** Malicious files disguised as legitimate downloads (music players, movies, games, greeting cards, screensavers, malicious MS Word/Excel macros, embedded in audio/video/subtitle files).
- **Email Attachments:** Most common medium, tricking victims into clicking malicious files.
- **Network Propagation:** Exploiting network vulnerabilities (e.g., Blaster worm, SQL Slammer).
- **File Sharing:** Exploiting open file-sharing ports (NetBIOS, FTP, SMB) to install malware.
- **Installation by other Malware:** One malware installing another.
- **Bluetooth and Wireless Networks:** Open Wi-Fi/Bluetooth networks used to capture user data.

Components of Malware

- **Crypter:** Encrypts malware to evade antivirus detection.
- **Downloader:** A Trojan that downloads other malware/malicious code.
- **Dropper:** Installs malware covertly (often embeds malicious files).
- **Exploit:** Code that takes advantage of a vulnerability.
- **Injector:** Injects exploits or malicious code into running processes.
- **Obfuscator:** Conceals malware code to make detection difficult.
- **Packer:** Compresses malware to make it unreadable.
- **Payload:** The malicious activity performed by the malware.
- **Malicious Code:** The core harmful functionality of the malware.

Potentially Unwanted Applications (PUAs)

- Also known as grayware/junkware.
- Applications that pose security risks (e.g., adware, toolbars, privacy risks).
- **Types of PUAs:**
 - **Adware:** Displays unsolicited advertisements (pop-ups, banners).
 - **Torrent:** Programs for downloading large files, often peer-to-peer file sharing.
 - **Marketing:** Monitor online activities for targeted advertising.
 - **Cryptomining:** Hijacks CPU to mine cryptocurrencies without user consent.
 - **Dialers:** Programs that automatically call numbers (often premium rate numbers).

Adware is software that displays unsolicited ads, collects user browsing data for marketing, and often comes bundled with free software to help developers generate revenue. While legitimate adware allows users to disable ads or opt-out with a paid version, malicious adware (often spyware) secretly collects personal data, slows down systems, and can compromise privacy and security.

Indications of Adware (1-line each):

1. **Frequent system lag** – System becomes sluggish due to adware consuming CPU and memory.
2. **Inundated advertisements** – Excessive, hard-to-close pop-ups flood the screen.
3. **Incessant system crash** – Frequent freezes or Blue Screen of Death (BSoD).
4. **Browser homepage changes** – Homepage is unexpectedly altered or redirects to suspicious sites.
5. **New toolbars/add-ons** – Unknown browser extensions or toolbars appear without permission.
6. **Slow Internet** – Internet speed drops due to background ad downloads.
7. **Unusual network traffic** – Surges in data usage indicate adware activity.

8. **Difficult software removal** – Adware resists uninstallation or reinstalls with other apps.
9. **Unauthorized data collection** – Browsing habits or personal data are secretly tracked for targeted ads.

2. Advanced Persistent Threat (APT) Concepts

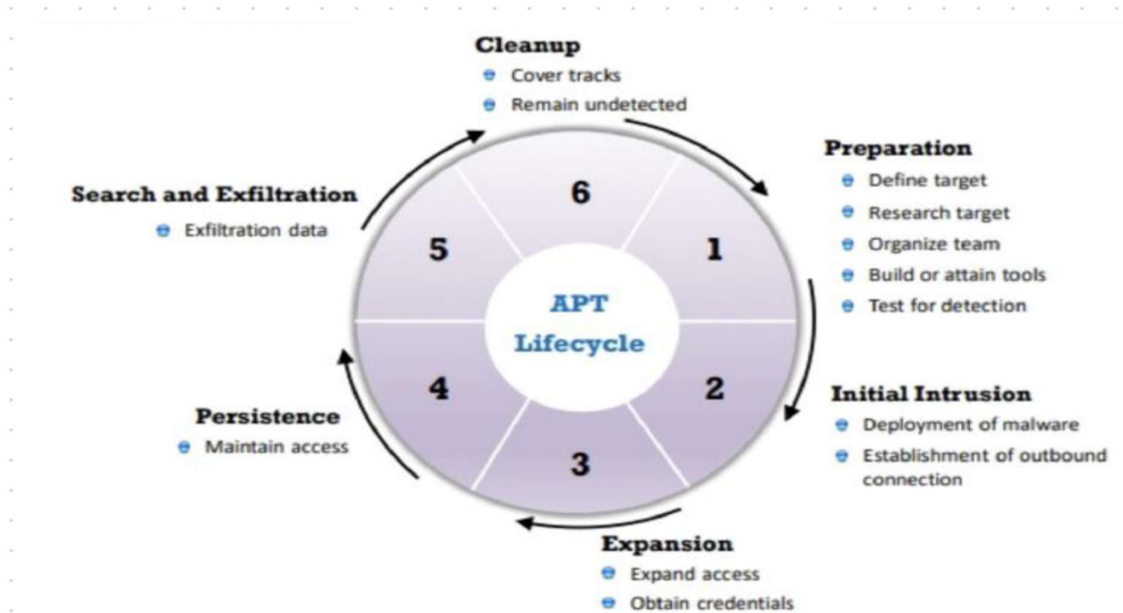
What are APTs? A type of network attack where an unauthorized person gains access to a network and stays there undetected for a long period.

- **Advanced:** Uses sophisticated techniques, zero-days, custom tools.
- **Persistent:** Long-term engagement within the target network.
- **Threat:** Refers to the human element behind the attack.

Characteristics of APTs:

- **Objectives:** Repeatedly obtain sensitive information, espionage.
- **Timeliness:** Long-term presence.
- **Resources:** Sophisticated tools and methods, highly skilled criminals.
- **Risk Tolerance:** Remain undetected in target networks for long periods.
- **Skills and Methods:** Social engineering, custom malware, evasion techniques.
- **Actions:** Different types of cyber attacks over a long time.
- **Attack Origin Points:** Multiple entry points to gain and launch further attacks.
- **Numbers Involved:** Can involve many hosts.
- **Knowledge Source:** Gathering information from various online sources.
- **Multi-Phased:** Follows multiple phases (reconnaissance, access, discovery, data exfiltration).
- **Tailored to Vulnerabilities:** Malicious code designed for specific targets.
- **Multiple Points of Entries:** Establishes connections to multiple servers.
- **Evading Signature-Based Detection Systems:** Uses zero-day exploits, rootkits, polymorphic malware.
- **Specific Warning Signs:** Unusual user account activities, backdoor Trojans, unusual file transfers.
- **Highly Targeted:** Meticulously planned against specific organizations or critical infrastructure.
- **Long-term Engagement:** Long-term presence within the target network.
- **Use of Advanced Techniques:** Spear-phishing, zero-day, rootkits, multi-stage malware.
- **Complex Command and Control (C2) Infrastructure:** Sophisticated and often obfuscated C2 channels.

Advanced Persistent Threat Lifecycle (6 Phases)



3. Trojans

What is a Trojan? A Trojan (Trojan horse) is a program with malicious or harmful code disguised as legitimate software. It performs hidden malicious functions without the user's consent.

How Hackers Use Trojans:

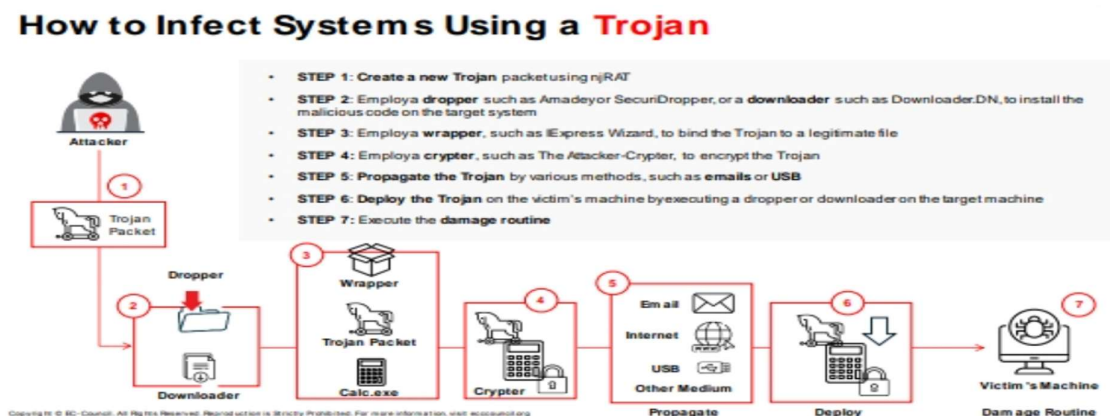
- Delete/replace OS critical files.
- Generate fake traffic for DoS attacks.
- Record screenshots, audio, video.
- Spam victims.
- Download spyware, adware, malicious files.
- Disable firewalls and antivirus.
- Gain remote access.
- Act as a proxy server for relaying attacks.
- Become part of a botnet for DDoS attacks.
- Steal sensitive information (credit card, bank, web service passwords, account data).
- Encrypt victim's machine/prevent access.

Common Ports Used by Trojans: Trojans often use specific ports for command and control or data transfer. The module provides a long list of specific Trojans and their corresponding ports (e.g., 2 (Death), 20/22/80/443 (Fireflotcker), 80 (NetMonitor), etc.). *For the exam, focus on understanding that Trojans utilize ports, rather than memorizing every single one.*

Types of Trojans

1. **Remote Access Trojans (RATs):** Provide full remote control over victim's system (e.g., Remcos RAT, Parallax RAT, AsyncRAT, Xeno RAT, MagicRAT).
2. **Backdoor Trojans:** Bypass standard authentication/security to gain access (e.g., TinyTurla-NG, SmokeLoader).
3. **Botnet Trojans:** Infect computers and make them part of a botnet for large-scale attacks (e.g., RDDos, Horabot, Satoni, Qakbot).
4. **Rootkit Trojans:** Hide malicious programs and processes from detection (e.g., Reptile Rootkit, Fire Chili Rootkit).
5. **E-Banking Trojans:** Target online banking credentials and financial data (e.g., Grandoreiro, Ursnif, IceID, Nexus, CHAFFCLOAK, Prilex).
6. **Point-of-Sale (POS) Trojans:** Target POS systems to steal credit card data (e.g., Prilex POS, LockPOS, FastPOS).
7. **Defacement Trojans:** Alter website content (e.g., Restorator).
8. **Service Protocol Trojans:** Exploit vulnerable service protocols (VNC, HTTP/HTTPS, ICMP) to attack systems (e.g., VNC Trojans, HTTP RAT, ICMP Trojans).
9. **Mobile Trojans:** Target mobile phones (e.g., Chameleon, Vultur).
10. **IoT Trojans:** Attack Internet of Things devices (e.g., OpenSSH Trojan).
11. **Security Software Disabler Trojans:** Stop the working of security programs (firewalls, IDS).
12. **Destructive Trojans:** Designed to delete files and disrupt system operations (e.g., SilverRAT, HermeticWiper).
13. **DDoS Attack Trojans:** Designed to launch Distributed Denial of Service attacks (e.g., Mirai botnet).
14. **Command Shell Trojans:** Provide remote control via a command shell (e.g., Netcat, DNS Messenger, GCat).

How to Infect Systems Using a Trojan



Propagate the Trojan: Through emails, covert channels, proxy servers, USB/Flash drives.

Overt vs. Covert Channels: Overt is legitimate communication; covert is hidden, used for exfiltration.

Overt Channel	Covert Channel
A legitimate communication path within a computer system or network for the transfer of data	A channel that transfers information within a computer system or network in a way that violates the security policy
Its idle components can be exploited to create a covert channel	An example of a covert channel is the communication between a Trojan and its command-and-control center

Techniques for Evading Antivirus Software (for Trojans):

- Breaking Trojan files into multiple pieces.
- Embedding into applications with signatures that AV recognizes as legitimate.
- Changing Trojan's syntax/extension (e.g., to VBScript, EXE, DLL).
- Changing checksum and encrypting files.
- Not downloading Trojans from untrusted web sources.
- Using binder and splitter tools.
- Perform code obfuscation or morphing.

4. Exploit Kits

What are Exploit Kits? Exploit kits (EKs) are toolkits used to exploit security loopholes in software applications. They are designed to automate the exploitation process.

How Attackers Use Exploit Kits:

1. Identify a vulnerable service/application.
2. Search for known exploits (e.g., on Exploit Database, VulDB).
3. Download the exploit code.
4. Modify if needed to suit environment.
5. Execute the exploit against the target.
6. Post-Exploitation activities (privilege escalation, data exfiltration, lateral movement).

Various Exploit Sites:

- **Exploit Database (Exploit-db.com):** A large repository of pre-written exploit code.
- **VulDB (vuldb.com):** Provides details on latest vulnerabilities and exploits, with exploitation probability ratings.
- **OSV (osv.dev):** Vulnerability database for open-source projects.
- **MITRE CVE (cve.org):** Database of vulnerabilities with CVE IDs.
- **Windows Exploit Suggester - Next Generation (WES-NG):** Python tool to find exploits for Windows OS by comparing systeminfo.exe output to a CVE database.

5. Viruses and Worms

Viruses

What is a Virus? A self-replicating malicious program that attaches itself to other executable files or documents (host program) and spreads. It requires human interaction (e.g., running an infected file) to propagate.

Characteristics of Viruses:

- Infects other programs.
- Transforms itself (polymorphic, metamorphic).
- Encrypts itself.
- Alters data.
- Corrupts files and programs.
- Replicates itself.

Purpose of Creating Viruses:

- Inflict damage on competitors.
- Realize financial benefits.
- Vandalize intellectual property.
- Play pranks.
- Conduct research.
- Engage in cyber-terrorism.
- Distribute political messages.
- Damage networks or computers.
- Gain remote access.

Indications of Virus Attack: Slow performance, system crashes, strange pop-ups, missing files, disabled antivirus, unusual network activity, unexpected reboots, etc.

Stages of Virus Lifecycle:

1. **Design:** Development of virus code.
2. **Replication:** Virus replicates itself and spreads.
3. **Launch:** Virus activated and performs malicious actions.
4. **Infection Phase:** Attaches to executable files, boot sectors, or scripts.
5. **Attack Phase:** Performs intended malicious activities (data deletion, system slowdown).

How a Computer Gets Infected by Viruses:

- Downloads from malicious websites.
- Email attachments.

- Pirated software.
- Failing to install security software/updates.
- Outdated browsers.
- Firewall misconfiguration.
- Pop-ups.
- Removable media (USB).
- Network access.
- Malicious online ads.
- Social media.

Types of Viruses:

- **System or Boot Sector Virus:** Infects Master Boot Record (MBR) or DOS boot record.
- **File Extension Virus:** Infects files with specific extensions (COM, EXE, SYS, OVL).
- **Multipartite Virus:** Infects both boot sectors and executable files.
- **Macro Virus:** Infects Microsoft Word/Excel documents using macros.
- **Cluster Viruses:** Modify directory table entries to point to virus instead of legitimate program.
- **Stealth/Tunneling Virus:** Evades detection by antivirus, hides itself.
- **Encryption Viruses:** Encrypt their code to avoid detection.
- **Sparse Infector Viruses:** Infests only occasionally, attempting to hide their presence.
- **Polymorphic Viruses:** Mutate their code with each infection, making signatures harder to detect.
- **Metamorphic Viruses:** Rewrite their code completely, making each instance unique.
- **Overwriting File or Cavity Viruses:** Overwrite part of a host file.
- **Companion/Camouflage Viruses:** Create a new executable with same name as legitimate program, running the virus instead.
- **Shell Viruses:** The virus code forms a shell around the target host program's code.
- **FAT Viruses:** Infect the File Allocation Table.
- **Logic Bomb Virus:** Triggers at a specific date/time or event.
- **Web Scripting Virus:** Exploits vulnerabilities in web browsers (XSS).
- **Email Viruses:** Spread via email attachments.
- **Armored Viruses:** Designed to confuse or trick antivirus software, difficult to trace.
- **Add-on Viruses:** Add their code to the host code without making changes to the latter.

- **Intrusive Viruses:** Overwrite the host code.
- **Direct Action or Transient Viruses:** Load into memory, execute, then unload.
- **Terminate and Stay Resident (TSR) Viruses:** Remain in memory after execution, controlling the system.

How to Infect Systems Using a Virus

- Step 1: Create a virus using tools such as JPS Virus Maker, Virus Maker, Virus-Builder, etc.
- Step 2: Once the virus is successfully created, pack it with a binder or virus packager tool
- Step 3: Send it to the victim's machine through email, chat, a mapped network drive, or other method that appears legitimate to the victim
- Step 4: When the victim opens and executes the received file, which seems to be legitimate, the target system gets infected

Virus Hoaxes & Fake Antivirus: False alarms claiming viruses or offering fake security software.

Some additional virus hoaxes are as follows: ▪ WhatsApp Seismic Waves Card ▪ McAfee Virus Pop-Up Scam ▪ McAfee Scam - Sinister Email

Antivirus 10 is a fake antivirus software pretending to be a legitimate antivirus suite.

Ransomware

Ransomware is a type of malware that restricts access to a computer system's files and folders and demands an online ransom payment to the malware creator(s) to remove the restrictions

Mallox

Mallox is a ransomware strain that targets Microsoft (MS) Windows systems and compromises networks with vulnerable MS-SQL servers

Some additional ransomware families are as follows: ▪ Phobos ▪ Xorist ▪ Conti ▪ Cerber ▪ Thanos ▪ RansomEXX ▪ NETWALKER ▪ QNAPCrypt ▪ Maze ▪ LockBit Black ▪ DarkSide RaaS

How to Infect Systems Using a Ransomware

- Step 1: Create a ransomware using tools such as Chaos Ransomware Builder v4 •
- Step 2: Transfer the ransomware to the victim's machine using various techniques, such as attaching it to an email or through physical means such as a hard drive or pen drive, making it appear legitimate
- Step 3: When the victim downloads and opens the malicious file, the ransomware infects the system by encrypting the system files based on the number of files and encryption algorithm
 - Step 4: After the infection, a window appears instructing the victim to pay a ransom for decrypting the files

Worms

Computer Worms

- Computer worms are malicious programs that **independently replicate, execute, and spread across the network connections**, thus consuming available computing resources without human interaction
- Attackers use worm **payloads to install backdoors** in infected computers, which turns them into **zombies** and **creates a botnet**; these botnets can be used to perform further cyber attacks

Worms:

- SSH-Snake
- Raspberry Robin
- P2PInfect

How is a Worm Different from a Virus?

A Worm Replicates on its own

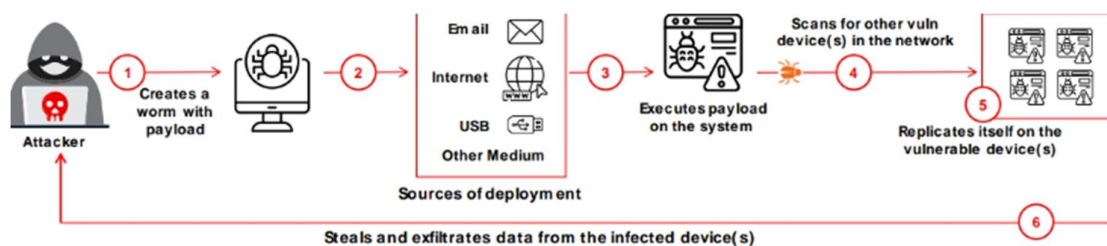
- A worm is a special type of malware that can replicate itself and use memory but cannot attach itself to other programs

A Worm Spreads through the Infected Network

- A worm takes advantage of file or information transport features on computer systems and automatically spreads through the infected network but a virus does not

Virus	Worm
A virus infects a system by inserting itself into a file or executable program	A worm infects a system by exploiting a vulnerability in an OS or application by replicating itself
It might delete or alter the content of files or change the location of files in the system	Typically, a worm does not modify any stored programs; it only exploits the CPU and memory
It alters the way a computer system operates without the knowledge or consent of a user	It consumes network bandwidth, system memory, etc., excessively overloading servers and computer systems
A virus cannot spread to other computers unless an infected file is replicated and sent to the other computers	A worm can replicate itself and spread using IRC, Outlook, or other applicable mailing programs after installation in a system
A virus spreads at a uniform rate, as programmed	A worm spreads more rapidly than a virus
Viruses are difficult to remove from infected machines	Compared with a virus, a worm can be removed easily from a system

Infection Method



STEP 1: Create a worm using tools such as Internet Worm Maker Thing or Batch Worm Generator
 STEP 2: Deploy the worm via phishing email, malicious website, network share, or infected USB drive
 STEP 3: When the user clicks on the phishing link or downloads content from a malicious website, the worm infects the system by executing its payload
 STEP 4: Through the infected system, the worm scans for other vulnerable devices in the network
 STEP 5: The worm copies itself to the identified vulnerable devices and propagates its infection
 STEP 6: The worm exfiltrates data from the infected devices

9. Fileless Malware Concepts

What is Fileless Malware? Fileless malware, also known as non-malware, infects legitimate software, applications, and other protocols existing in the system to perform various malicious activities

- It leverages any existing vulnerabilities to infect the system

It resides in the system's RAM. It injects malicious code into the running processes such as Microsoft Word, Flash, Adobe PDF Reader, JavaScript, and PowerShell

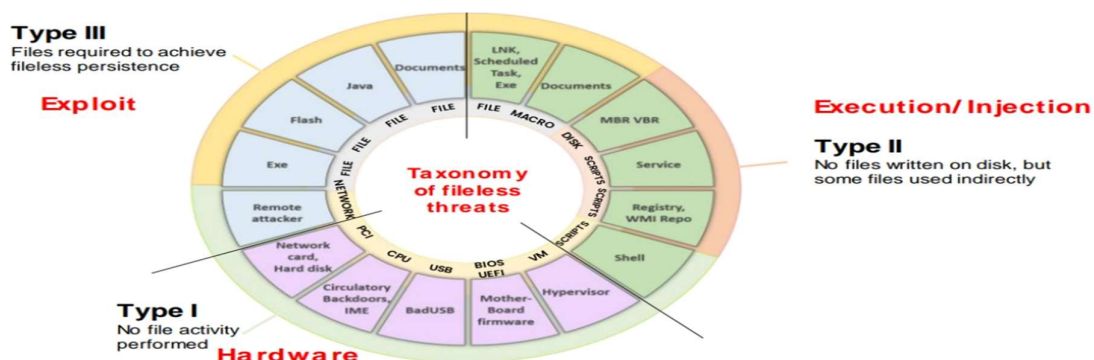
Reasons for Fileless Malware Attacks:

- **Stealth:** Extremely difficult to detect.
- **LOL (Living off the land):** Exploits tools already installed on the system (e.g., PowerShell, WMI).
- **Trustworthiness:** Uses trusted system tools for malicious activities.
- **Persistence:** Achieves persistence without storing files on disk (e.g., modifying registry).
- **Simplifying Infection:** Simple phishing emails lead to memory-based infection.
- **Increased Success Rate:** Evades traditional AV/IDS.
- **Complicating Forensics:** Leaves minimal traces, making analysis harder.

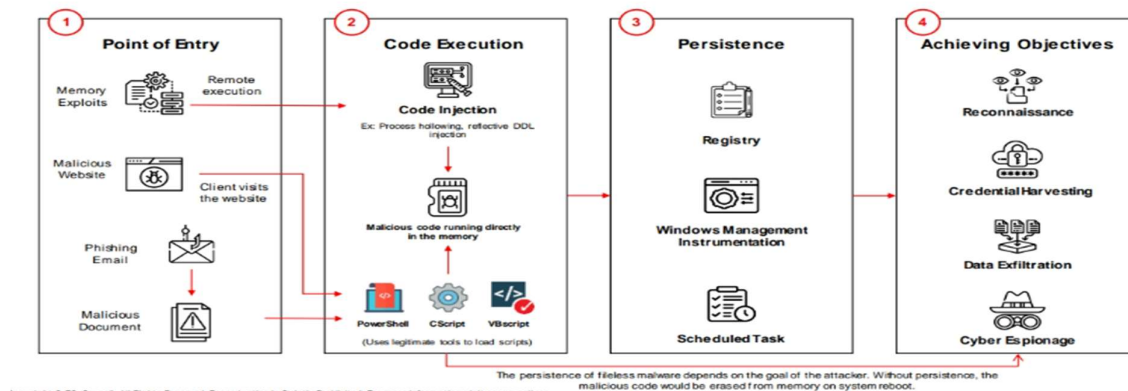
Fileless Propagation Techniques Used by Attackers

- **Phishing Emails/Malicious Documents:** Embeds malicious macros, links.
- **Legitimate Applications:** Exploits legitimate programs (Word, Java, JavaScript, PowerShell).
- **Native Applications:** Uses pre-installed system tools (WMI, PowerShell).
- **Infection through Lateral Movement:** Moves laterally in memory.
- **Malicious Websites:** Exploits browser vulnerabilities to run malicious code.
- **Registry Manipulation:** Injects code into the Windows Registry for persistence.
- **Memory Code Injection:** Injects malicious code into running processes.
- **Script-Based Injection:** Obfuscated scripts embedded in documents.
- **Reflective DLL Injection:** Loads a DLL directly into memory.
- **Exploiting Non-Malicious Files:** Uses legitimate files (PDFs, shortcuts) to run malicious scripts.

Taxonomy of Fileless Malware Threats



How does Fileless Malware **Work?**



- Launching Fileless Malware
 - **Memory Exploits:** Inject a malicious payload into the RAM, exploit different Win APIs.
 - **Malicious Document:** Trick users into downloading a file consisting of malicious macro code.
 - **Script-Based Injection:** Allow attackers to communicate and infect the applications or OS without being traced
 - **Exploiting System Admin Tools:** Exploit system admin tools such as Certutil, WMIC, and Regsvr32 to launch fileless infections. Exploit cmd tools such as **Regsvr32**, and **rundll32** to run malicious DLLs.
 - **Through windows Registry:** The modification of the ExecutionPolicy settings in the registry to "unrestricted" or "bypass" can facilitate the execution of malicious scripts. Attackers can exploit such vulnerabilities in the Windows registry to deploy fileless malware on targeted systems. Attackers may use malware such as Kovter for the execution
 - **Through Phishing:** Use social engineering techniques. Fileless malware exploits vulnerabilities in system tools to load and run malicious payloads to compromise the sensitive info stored in the process memory.

• Main Persistence with Fileless Techniques

- **Do not use disk files** to spread its infection or main persistence
- Adopt unique methods such as **developing load points** to restart infected payload
- Save the malicious payload **inside the registry** that hold data for configuration, application files, and settings, which executes itself with every restart

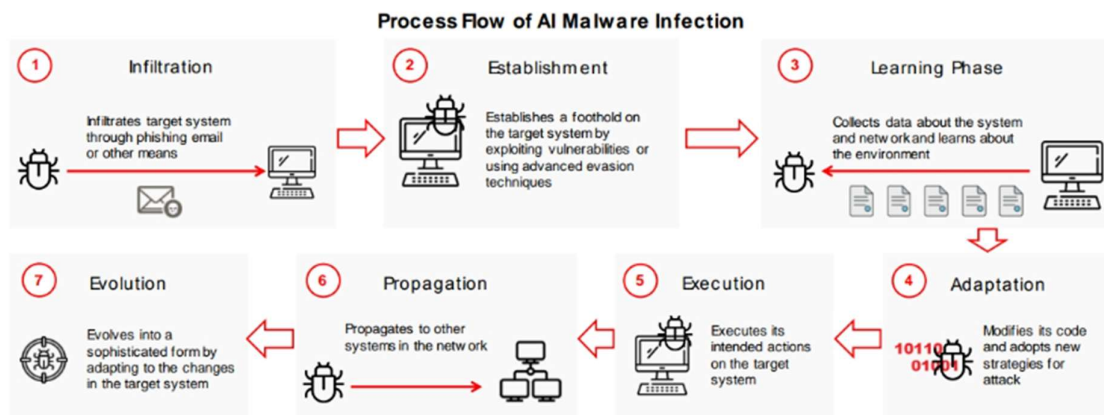
- **Fileless Malware:** Divergent is a type of fileless malware that **depends mostly on the registry** for the....It also employs a key in the register to **maintain persistence** and exploits PowerShell to inject itself on to the other processes.

Fileless Malware Obfuscation Techniques to Bypass Antivirus

1. **Inserting Characters** – Special characters (,, ;) are added to break up known commands and avoid signature-based detection.
2. **Inserting Parentheses** – Parentheses are used to split commands into blocks that execute as a single line, evading pattern matching.
3. **Inserting Caret Symbol** – The caret (^) is used to escape characters, disguising the actual command until runtime.
4. **Inserting Double Quotes** – Double quotes (") split and concatenate commands to obfuscate payloads and evade scanning tools.
5. **Using Custom Environment Variables** – Malicious commands are split across environment variables and recombined during execution.
6. **Using Pre-assigned Environment Variables** – System-defined variables are indexed to reconstruct and execute malicious code stealthily.

10. AI-Based Malware Concepts

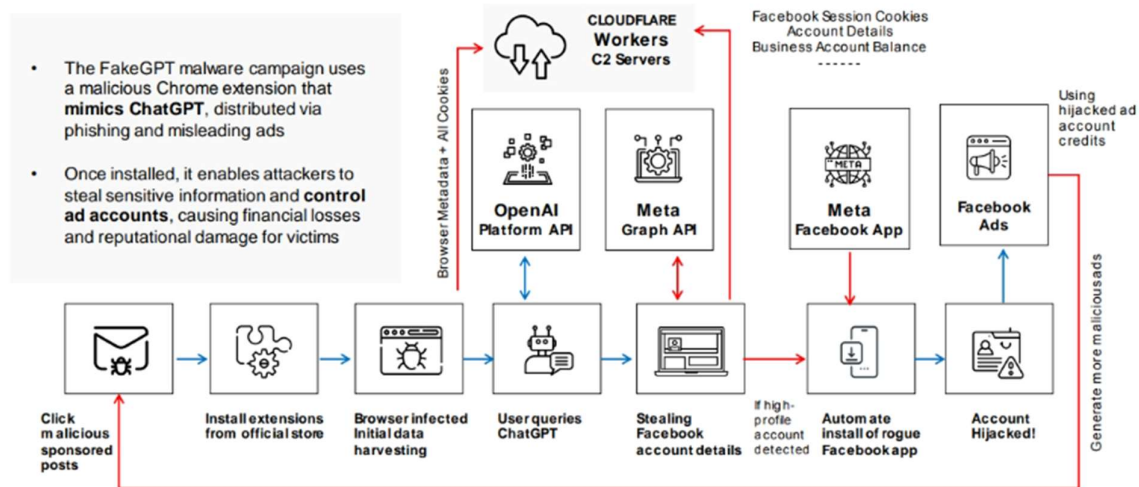
What is AI-Based Malware? Malware that utilizes Artificial Intelligence (AI) or Machine Learning (ML) to enhance its capabilities.



How AI-Based Malware Works:

- **Autonomous Operation:** Learns and adapts to evade detection and spread.
- **Polymorphic Behavior:** Changes its code using AI to bypass signature-based detection.
- **Evasion Techniques:** AI helps malware learn and adapt to security measures.
- **Targeted Attacks:** AI identifies vulnerable targets and customizes attacks.
- **Automated Reconnaissance:** AI automates data collection for targets.
- **Decision-Making:** AI chooses optimal attack paths.
- **Advanced Social Engineering:** AI creates highly convincing phishing attacks.
- **Swarm Intelligence:** Multiple AI-powered malware instances coordinate attacks.

Examples of AI-based Malware: FakeGPT



WormGPT

- WormGPT is an AI-based chatbot built upon open-sourced GPT-J LLM (large language model) capable of interpreting and responding to natural language text
- Attackers can use WormGPT to enter prompts that generate human-like replies for fake emails that they can use to lure users into disclosing critical information and sending money

FraudGPT

FraudGPT is a malicious AI-driven tool tailored similarly to ChatGPT, but it produces deceptive content for malicious activities

- Attackers can use this tool to generate deceptive content such as convincing phishing mails and social engineering tactics, creating cracking tools, engaging in carding activities, identifying vulnerabilities, and many other malicious activities

11. Malware Analysis Process

Sheep Dip Computer

In information security and malware analysis, sheep dipping refers to the analysis of suspicious files, incoming messages, etc., for malware.

- Is installed with port monitors, files monitor...Connect to a network only under strictly controlled conditions

Antivirus Sensor Systems

- A collection of computer software that detects and analyzes malicious code threats such as viruses, worms, and trojans.
- They are used along with sheep dig computer.

What is Malware Analysis? The process of understanding the functionality, origin, and potential impact of a given malware sample.

Malware analysis involves the following steps: 1. Preparing Testbed 2. Static Analysis 3. Dynamic Analysis

Types of Malware Analysis

- **Static Malware Analysis:**
 - Examines the malware without executing it.
 - Looks at the code, resources, metadata.
 - **Techniques:** Antivirus Scanning, Hashing, String Search, File Identification, Feature Extraction, Disassembly, Debugging.
 - **Tools:** Virustotal, PeStudio, CFF Explorer, BinText, Strings, UPX, IDA Pro, OllyDbg, Ghidra, Bytecode Viewer.
 - **Limitations:** Can be time-consuming, may miss hidden functionalities, not suitable for polymorphic/metamorphic malware, doesn't interact with systems.
- **Dynamic Malware Analysis:**
 - Executes the malware in a controlled, isolated environment (sandbox, virtual machine).
 - Observes its behavior, system changes, network activity.
 - **Techniques:** System Monitoring, Network Monitoring, Process Monitoring, Registry Monitoring, File System Monitoring, Memory Analysis.
 - **Tools:** Process Monitor, Wireshark, Regshot, Process Explorer, ApateDNS, SysAnalyzer, Cuckoo Sandbox, Any.Run, Hybrid Analysis, VMRay, Joe Sandbox.
 - **Limitations:** Risk of malware escape, requires isolated environment, might not uncover all functionalities (e.g., time-delayed payloads), some malware can detect sandboxes.

Malware Analysis Procedure: Preparing Testbed

1. Allocate a physical system for the analysis lab
2. Install a Virtual machine (VMware, Hyper-V, etc.) on the system
3. Install guest OS on in the Virtual machine(s)
4. Isolate the system from the network by ensuring that the NIC card is in "host only" mode
5. Simulate internet services using tools such as INetSim
6. Disable the "shared folders" and "guest isolation"
7. Install malware analysis tools
8. Generate the hash value of each OS and tool
9. Copy the malware over to the guest OS

Some of the static malware analysis techniques

1. **File fingerprinting:** File fingerprinting is the process of computing the hash value for a given binary code tools like HashMyFiles to calculate various hash values of the malware file
2. **Local and online malware scanning :** Scan the binary code locally using well-known and up-to-date antivirus software upload the code to online websites such as VirusTotal to get it scanned by a wide-variety of different scan engines
3. **Performing string search :** Analyze embedded strings of the readable text within the program's executable file

- Example: Status update strings and error strings • Use tools such as BinText to extract embedded strings from executable files
- 4. Identifying packing/ obfuscation methods: Attackers often use packers to compress, encrypt, or modify a malware executable file to avoid detection •
It complicates the task for the reverse engineers in finding out the actual program logic and other metadata via static analysis • Use tools such as PEid that detects most common packers, cryptors, and compilers for PE executable files
- 5. Finding the portable executables (PE) information: Analyze the metadata of PE files to get information such as time and date of compilation, functions imported and exported by the program, linked libraries, icons, menus, version information, and strings that are embedded in resources
- 6. Identifying file dependencies: File dependencies contain information about the internal system files that the program needs to function properly Use tools such as DependencyWalker to identify the dependencies within the executable file
- 7. Malware disassembly : Disassemble the binary code and analyze the assembly code instructions Use tools such as IDA that can reverse the machine code to assembly language • Based on the reconstructed assembly code, you can inspect the program logic and recognize its threat potential. This process is performed using debugging tools such as OllyDbg
- 8. Analyzing ELF Executable Files : tatic Analysis of ELF Files Using readelf
 - Identify symbols in ELF executables: readelf -s <malware-sample> Intezer is a malware analysis platform that scans files, URLs, endpoints, and memory du
- 9. Analyzing Mach-O Executable Files: Mach-O is an executable file format for macOS and iOS that is similar to the PE format for Windows and ELF for Linux
- 10. Analyzing Malicious MS Office Documents: oletools is a suite of Python tools specifically designed for analyzing Microsoft OLE2 files, commonly found in Microsoft Office documents
 - The toolkit can extract, parse, and detectmalicious content within these files

YARA (Yet Another Recursive Acronym) is a powerful tool used for identifying and classifying malware samples

It works by allowing users to create rules that describe patterns of interest in files, which can include specific strings, binary sequences, or a combination of characteristics that typically appear in malware

Dynamic Malware Analysis: Behavioral analysis involves executing the malware code

- Require a safe environment such as **virtual machines** and **sandboxes**
- **System Baseline** : Take a snapshot of the system, compare
- **Host Integrity Monitoring:**
 - **Port:** netstat, TCPView
 - **Process:** Process Monitor
 - **Registry:** jv16 PowerTools
 - **Service:** Windows Service Monitoring Tools
 - **Startup:** Autoruns for Windows, C:\ ProgramData\Microsoft \Windows\Start Menu\Programs\Startup

- **Event Logs:** Splunk is a SIEM (Security Information and Event Management) tools that...
- **Installation:** Mirebusoft Install Monitor
- **File and Folders:** PA File Sight
- **Drivers:** DriverView, run->msinfo32->Software Environment->System Drivers
- **Network traffic:** SolarWinds NetFlow Traffic Analyzer
- **DNS/Resolution:** DNSQuerySniffer
- **API Calls:** API Monitor
- **System Calls Monitoring**

Virus Detection **Methods**

Scanning	Once a virus is detected, it is possible to write scanning programs that look for signature string characteristics of the virus
Integrity Checking	Integrity checking products work by reading the entire disk and recording integrity data that act as a signature for the files and system sectors
Interception	The interceptor monitors the operating system requests that are written to the disk
Code Emulation	• In code emulation techniques, the antivirus executes the malicious code inside a virtual machine to simulate CPU and memory activities • These techniques are considered very effective in dealing with encrypted and polymorphic viruses if the virtual machine mimics the real machine
Heuristic Analysis	• Heuristic analysis can be static or dynamic • In static analysis, the antivirus analyses the file format and code structure to determine if the code is viral • In dynamic analysis, the antivirus performs a code emulation of the suspicious code to determine if the code is viral

SCEMU is an x86 32/64-bit emulator designed to securely emulate malware. It features all dependencies and zero unsafe{} blocks.

Trojan Analysis: Coyote

Attackers often strive for innovation or the creation of new malware components to explore opportunities to exploit and steal data from target systems or users. With similar motives, attackers created a deadly banking trojan known as “Coyote.”

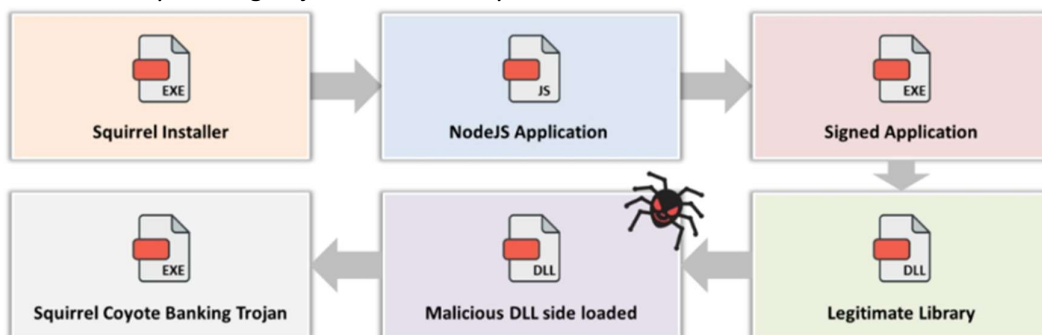


Figure 7.141: Illustration of Coyote working

Fileless Malware Analysis: PyLoose

PyLoose, a Python-based fileless malware designed to target cloud workloads, is typically used for storage and computation. The malware exploits these resources for long-term cryptomining.

Malware Analysis Environment

- **Virtual Machine (VM):** Essential for safe dynamic analysis. Allows isolation and snapshotting.
- **Sandbox:** Automated analysis environment that executes malware and records its behavior.
- **Network Configuration:** Isolated network setup to prevent malware propagation.
- **Tools:** Windows OS with necessary tools (Process Monitor, Wireshark), Linux OS (Remnux) for additional tools.

Sandbox Evasion Techniques by Malware

- **Checking for Human Activity:** Malware checks for mouse movements, keyboard input.
- **Checking for Malware Analysis Tools:** Detects presence of debuggers, network monitors.
- **Checking for VM Artifacts:** Looks for virtual machine drivers, specific registry keys.
- **Environmental Detections:** Checks for specific CPU core counts, memory size, disk space.
- **Time-Based Triggers:** Delays execution until a specific date/time.
- **User Interaction Triggers:** Requires user clicks or specific actions.
- **Network Connectivity Checks:** Waits for internet access or specific server responses.
- **Obfuscation and Encryption:** Hides malicious code until executed.
- **Anti-Debugging/Anti-Disassembly:** Techniques to hinder analysis.

12. Malware Countermeasures

Antivirus Software

- Detects and removes malware.
- **Detection Techniques:** Signature-based, Heuristic-based, Behavior-based, Sandboxing, Data Mining.

Anti-Malware Solutions

- Provide protection beyond traditional antivirus.
- **Key Features:** Real-time protection, behavior monitoring, cloud-based analysis, advanced threat detection.

Mobile Malware Countermeasures

- Use official app stores.
- Review app permissions.
- Keep OS/apps updated.

- Use mobile security solutions.
- Be wary of unknown links/attachments.

Ransomware Countermeasures

- Regular backups.
- Email security (spam filters, attachment scanning).
- Endpoint protection (AV, EDR).
- Network segmentation.
- Patch management.
- User awareness training.
- Incident response plan.

Endpoint Protection Platforms (EPP) and Endpoint Detection and Response (EDR)

- **EPP:** Preventative controls on endpoints (antivirus, firewall, DLP).
- **EDR:** Detects, investigates, and responds to threats on endpoints (continuous monitoring, behavioral analysis, threat hunting).

Other Countermeasures

- **Security Best Practices:** Regular patching, strong passwords, network segmentation, firewall rules.
- **Network Security Devices:** Firewalls, IDS/IPS.
- **Data Loss Prevention (DLP):** Prevents sensitive data exfiltration.
- **Sandboxing:** Running suspicious files in isolated environments.
- **User Awareness Training:** Educating users about malware risks.
- **Incident Response Plan:** Defined procedures for handling security incidents.

Key Terms for Last-Minute Revision

- **Malware:** Malicious Software
- **Trojans:** Disguised malicious programs
- **Backdoors:** Bypasses security for persistent access
- **Rootkits:** Hides malicious processes
- **Ransomware:** Encrypts data, demands ransom
- **Adware:** Displays unwanted ads
- **Crypter:** Encrypts malware to evade AV
- **Dropper:** Installs malware covertly

- **Exploit Kit (EK):** Automates vulnerability exploitation
- **APT (Advanced Persistent Threat):** Long-term, sophisticated, targeted attack
- **CVSS:** Vulnerability scoring system
- **CVE:** Publicly known vulnerabilities
- **SAM Database:** Windows password hash storage
- **NTLM:** Challenge/response authentication protocol
- **Kerberos:** Ticket-based network authentication protocol
- **KDC (Key Distribution Center):** Kerberos component (AS + TGS)
- **TGT (Ticket-Granting Ticket):** Kerberos authentication ticket
- **RAT (Remote Access Trojan):** Full remote control
- **POS Trojan:** Targets Point-of-Sale systems
- **Fileless Malware:** Operates in memory, no disk writes
- **LOL (Living Off the Land):** Using legitimate system tools for malicious activities
- **Static Malware Analysis:** Analysis without execution
- **Dynamic Malware Analysis:** Analysis by executing in a controlled environment
- **Sandbox:** Isolated environment for dynamic analysis
- **Polymorphic Malware:** Changes code to avoid detection
- **Metamorphic Malware:** Rewrites code completely for each infection
- **Worm:** Self-replicating malware, spreads independently
- **Virus:** Self-replicating malware, needs host program/user interaction to spread
- **AI-Based Malware:** Uses AI/ML for enhanced capabilities
- **EPP (Endpoint Protection Platform):** Preventative endpoint security
- **EDR (Endpoint Detection and Response):** Detects, investigates, responds to endpoint threats
- **DLP (Data Loss Prevention):** Prevents sensitive data exfiltration